

## **Bilag 14**

### Sikkerhed

**[Vejledning til tilbudsgiver:**

*Bilaget skal ikke udfyldes af tilbudsgiver i forbindelse med afgivelse af tilbud.*

*Dette vejledningsafsnit slettes, inden Kontrakten underskrives.]*

## 1. INDLEDNING

På baggrund Kundens risikovurdering fastsættes nedenstående sikkerhedskrav.

## 2. SIKKERHEDSPOLITIK

| Krav-ID | Krav                                                                                                                                                                                                                                                                                                                                                                                                       | ISO27001-referenc e | ENISA referen ce |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K1      | Leverandøren skal fastlægge et sæt politikker for informationssikkerhed i relation til Kontraktens opfyldelse.                                                                                                                                                                                                                                                                                             | A.5.1.1             | A.1              |
| K2      | Leverandørens politikker for informationssikkerhed i relation til Kontraktens opfyldelse skal gennemgås med planlagte mellemrum og om nødvendigt <i>årligt</i> .                                                                                                                                                                                                                                           | A.5.1.2             | A.2 (NB A.6)     |
| K3      | Leverandøren skal i relation til Kontraktens opfyldelse fastlægge et dedikeret sæt sikkerhedspolitikker for behandling af personoplysninger, som skal godkendes af Leverandørens ledelse og kommunikeres til Leverandørens medarbejdere og eventuelle samarbejdspartnere.                                                                                                                                  | A.5.1.1             | A.3              |
| K4      | Leverandørens sikkerhedspolitik i relation til Kontraktens opfyldelse skal som minimum beskrive: <ul style="list-style-type: none"> <li>• Medarbejdernes roller og ansvar,</li> <li>• de tekniske og organisatoriske foranstaltninger, der er vedtaget for at sikre personoplysninger,</li> <li>• databehandlere eller andre tredjeparter, der er involveret i behandling af personoplysninger.</li> </ul> | N/A                 | A.4              |
| K5      | Leverandøren skal i relation til Kontraktens opfyldelse udarbejde en oversigt over specifikke politikker/procedurer vedrørende sikkerheden af personoplysninger baseret på den generelle sikkerhedspolitik.                                                                                                                                                                                                | N/A                 | A.5              |
| K6      | Leverandørens politikker for informationssikkerhed i relation til Kontraktens opfyldelse skal gennemgås med planlagte mellemrum og om nødvendigt <i>hvert halve år</i> .                                                                                                                                                                                                                                   | A.5.1.2             | A.6 (NB A.2)     |

## 3. ORGANISERING AF INFORMATIONSSIKKERHED

| Krav-ID | Krav | ISO27001- referenc e | ENISA referen ce |
|---------|------|----------------------|------------------|
|---------|------|----------------------|------------------|

|     |                                                                                                                                                                                                                       | referenc<br>e |     |
|-----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------|-----|
| K7  | Leverandøren skal definere og fordele alle ansvarsområder for informationssikkerhed i relation til Kontraktens opfyldelse blandt Leverandørens medarbejdere.                                                          | A.6.1.1       | B.1 |
| K8  | Leverandøren skal sikre, at rettigheder og ansvar tilpasses og/eller tilbagekaldes i overensstemmelse med klart definerede procedurer i forbindelse med interne reorganisationer, ansættelsesændringer og opsigelser. | A.6.1.1       | B.2 |
| K9  | Leverandøren skal udpege personer med ansvar for specifikke sikkerhedsopgaver, herunder udpege en sikkerhedsansvarlig.                                                                                                | A.6.1.1       | B.3 |
| K10 | Leverandøren skal formelt udnævne den sikkerhedsansvarlige og klart definere den sikkerhedsansvarliges opgaver og ansvar.                                                                                             | A.6.1.1       | B.4 |
| K11 | Leverandøren bør sikre, at modstridende funktioner, herunder den sikkerhedsansvarlige og DPO'en, adskilles for at nedsætte muligheden for uautoriseret eller utilsigtet ændring eller misbrug af personoplysninger.   | A.6.1.2       | B.5 |

#### 4. ADGANGSSTYRING

| Krav<br>-ID | Krav                                                                                                                                                                                                         | ISO2700<br>1-<br>referenc<br>e | ENISA<br>referen<br>ce |
|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------|------------------------|
| K12         | Leverandøren skal sikre, at Leverandørens medarbejdere kun har adgang til de personoplysninger, som de specifikt er autoriseret til at benytte i relation til Kontraktens opfyldelse.                        | A.9.1.2                        | C.1                    |
| K13         | Leverandøren skal fastlægge, dokumentere og vedligeholde en politik for adgangsstyring i relation til Kontraktens opfyldelse i overensstemmelse med den til enhver tid gældende risikovurdering.             | A.9.1.1                        | C.2                    |
| K14         | Leverandøren skal fastlægge og dokumentere adskillelse af adgangskontrolfunktioner, herunder adgangsforespørgsel, adgangsauctorisation og adgangsadministration.                                             | A.9.1.1                        | C.3                    |
| K15         | Leverandøren skal definere medarbejderroller med privilegerede adgangsrettigheder, samt begrænse og styre tildeling og anvendelse af privilegerede adgangsrettigheder i relation til Kontraktens opfyldelse. | A.9.2.3                        | C.4                    |

## 5. STYRING AF AKTIVER

| Krav-ID | Krav                                                                                                                                                                                                                                                                                                                         | ISO27001-referenc e | ENISA referen ce |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K16     | Leverandøren skal identificere de informationsaktiver (hardware, software, og netværk), der anvendes til Kontraktens opfyldelse, og udarbejde og vedligeholde en fortegnelse over disse informationsaktiver. Leverandøren skal endvidere udpege en medarbejder, der skal være ansvarlig for vedligeholdelse af fortegnelsen. | A.8.1.1             | D.1              |
| K17     | Leverandøren skal sikre at fortegnelsen over informationsaktiver gennemgås og vedligeholdes <i>regelmæssigt</i> .                                                                                                                                                                                                            | A.8.1.1             | D.2 (NB D.4)     |
| K18     | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at medarbejderfunktioner med adgang til kritiske informationsaktiver defineres og dokumenteres.                                                                                                                                                               | A.9.1.1             | D.3              |
| K19     | Leverandøren skal sikre at fortegnelsen over informationsaktiver gennemgås og vedligeholdes <i>årligt</i> .                                                                                                                                                                                                                  | A.8.1.4             | D.4 (NB D.2)     |

## 6. DRIFTSPROCEDURER OG ANSVARSOMRÅDER

| Krav-ID | Krav                                                                                                                                                                                                                                                                                                                   | ISO27001-referenc e | ENISA referen ce |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K20     | Leverandøren skal anvende dokumenterede driftsprocedurer, herunder ændringsprocedurer, i it-systemer der anvendes i forbindelse med Kontraktens opfyldelse. Leverandøren skal endvidere regelmæssigt overvåge disse procedurer.                                                                                        | A.12.1.1            | E.1              |
| K21     | Leverandøren skal adskille udviklings-, test- og driftsmiljøer i relation til Kontraktens opfyldelse for at nedsætte risikoen for uautoriseret adgang til eller ændringer af driftsmiljøet, hvori der behandles personoplysninger. Der må ikke testes på personoplysninger uden forudgående konkret aftale med Kunden. | A.12.1.4            | E.2              |
| K22     | Leverandøren skal styre ændringer af Leverandørens organisation, forretningsprocesser, informationsbehandlingsfaciliteter og -systemer, som påvirker informationssikkerheden i relation til                                                                                                                            | A.12.1.2            | E.3              |

Kontraktens opfyldelse. Leverandørens ændringspolitik skal opdateres regelmæssigt.

## 7. LEVERANDØRFORHOLD

| Krav-ID | Krav                                                                                                                                                                                                                                                                                                                                                                                                                                 | ISO27001-referenc e | ENISA referen ce |
|---------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K23     | Leverandøren skal sikre, at retningslinjer mv. vedrørende informationssikkerhed forbundet med underleverandørers adgang til personoplysninger, der anvendes til Kontraktens opfyldelse, aftales med underleverandører og dokumenteres. Leverandøren skal sikre at disse aftaler afspejler kravene til sikkerhed til Leverandøren og er passende henset til den gældende risikovurdering.                                             | A.15.1.1            | F.1              |
| K24     | Leverandøren skal fastlægge og aftale alle relevante informationssikkerhedskrav med hver enkelt underleverandør, som kan få adgang til, behandle, lagre, kommunikere eller levere it-infrastrukturkomponenter til information omfattet af Kontrakten. Leverandøren skal herunder sikre, at underleverandører orienterer Leverandøren om sikkerhedsbrud uden ugrundet ophold og i overensstemmelse med databehandleraftalen i øvrigt. | A.15.1.2            | F.2              |
| K25     | Leverandøren skal sikre, at der indgås skriftlige aftaler med underleverandører om sikkerhed, og underleverandører skal dokumentere opfyldelse af disse aftaler.                                                                                                                                                                                                                                                                     | A.15.1.2            | F.3              |
| K26     | Leverandøren skal regelmæssigt overvåge, gennemgå og auditere underleverandørydelser, der anvendes til Kontraktens opfyldelse, og påse disse underleverandørydelsers overensstemmelse med de indgåede underleverandøraftaler.                                                                                                                                                                                                        | A.15.2.1            | F.4              |
| K27     | Leverandøren skal sikre, at de medarbejdere hos underleverandøren, der behandler personoplysninger, er pålagt tavsheds- og fortrolighedsklausuler.                                                                                                                                                                                                                                                                                   | A.15.1.2            | F.5              |

## 8. STYRING AF INFORMATIONSSIKKERHEDSBRUD

| Krav-ID | Krav | ISO27001-referenc e | ENISA referen ce |
|---------|------|---------------------|------------------|
|---------|------|---------------------|------------------|

|     |                                                                                                                                                                                                                                                                             |          |     |
|-----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|-----|
| K28 | Leverandøren skal fastlægge ledelsesansvar og procedurer for at sikre hurtig, effektiv og planmæssig håndtering af informationssikkerhedsbrud relateret til Kontraktens opfyldelse.                                                                                         | A.16.1.1 | G.1 |
| K29 | Leverandøren skal sikre, at informationssikkerhedshændelser relateret til Kontraktens opfyldelse rapporteres ad passende ledelseskanaler så hurtigt som muligt og i overensstemmelse med databehandleraftalen, samt databeskyttelsesforordningens artikel 33 og artikel 34. | A.16.1.2 | G.2 |
| K30 | Leverandøren skal sikre, at informationssikkerhedsbrud i relation til Kontraktens opfyldelse håndteres i overensstemmelse med de dokumenterede procedurer.                                                                                                                  | A.16.1.5 | G.3 |
| K31 | Leverandøren skal sikre, at der i forbindelse med Kontraktens opfyldelse defineres og anvendes procedurer til identifikation, indsamling, anskaffelse og opbevaring af informationer, som kan tjene som bevis relateret til sikkerhedsbruddet.                              | A.16.1.7 | G.4 |

## 9. INFORMATIONSSIKKERHEDSASPEKTER AF FORRETNINGSKONTINUITETSSTYRING

| Krav-ID | Krav                                                                                                                                                                                                                                                                              | ISO27001-referenc e | ENISA referen ce |
|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K32     | Leverandøren skal i relation til Kontraktens opfyldelse fastlægge krav til informationssikkerhed og informationssikkerhedskontinuitet i kritiske situationer, fx i tilfælde af en krise eller katastrofe.                                                                         | A.17.1.1            | H.1              |
| K33     | Leverandøren skal i relation til Kontraktens opfyldelse fastlægge en BCP (Business Continuity Plan), herunder dokumentere, implementere og vedligeholde processer, procedurer og kontroller for at sikre den nødvendige informationssikkerhedskontinuitet i en kritisk situation. | A.17.1.2            | H.2              |
| K34     | Leverandørens BCP skal definere et garanteret kvalitetsniveau for centrale forretningsprocesser vedrørende sikkerhed for personoplysninger.                                                                                                                                       | A.17.1.1            | H.3              |
| K35     | Leverandøren skal udpege personale i Leverandørens organisation, der har det nødvendige ansvar, autoritet og kompetence til at sørge for kontinuitet i Leverandørens organisation i tilfælde af brud på persondatasikkerheden.                                                    | A.17.1.2            | H.4              |

|     |                                                                                                                                                                          |          |     |
|-----|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|-----|
| K36 | Leverandøren skal sikre, at informationsbehandlingsfaciliteter implementeres med tilstrækkelig redundans til at kunne imødekomme tilgængelighedskravene for it-systemet. | A.17.1.3 | H.5 |
|-----|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|-----|

## 10. PERSONALESIKKERHED

| Krav-ID | Krav                                                                                                                                                                                                                                                                                                                         | ISO27001-referenc e | ENISA referen ce |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K37     | Leverandøren skal sikre, at alle medarbejdere og kontrahenter opretholder informationssikkerhed i overensstemmelse med organisationens fastlagte politikker og procedurer i relation til Kontraktens opfyldelse.                                                                                                             | A.7.2.1             | I.1              |
| K38     | Leverandøren skal sikre, at kontrakter med medarbejdere og kontrahenter, der medvirker til Kontraktens opfyldelse, beskriver de pågældendes og Leverandørens ansvar for informationssikkerhed, eller medarbejdere og kontrahenter på anden måde gøres bekendt med og accepterer Leverandørens informationssikkerhedspolitik. | A.7.1.2             | I.2              |
| K39     | Leverandøren skal pålægge medarbejdere, der er involveret i behandling af personoplysninger, som indebærer en høj risiko for den registreredes rettigheder, at underskrive en fortrolighedsklausul i tilknytning til deres ansættelseskontrakt eller tilsvarende.                                                            | N/A                 | I.3              |

## 11. BEVIDSTHED OM INFORMATIONSSIKKERHED, UDDANNELSE OG TRÆNING

| Krav-ID | Krav                                                                                                                                                                                                                                                                                                                                                                                | ISO27001-referenc e | ENISA referen ce |
|---------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K40     | Leverandøren skal sikre, at Leverandørens medarbejdere er tilstrækkeligt informeret om sikkerhedsforanstaltninger i de dele af it-systemet, der er relevante for deres jobfunktion. Endvidere skal medarbejdere, der er involveret i behandling af personoplysninger, gennem awareness-kampagner informeres om relevante databeskyttelseskrav og relevante juridiske forpligtelser. | A.7.2.2             | J.1              |

|     |                                                                                                                                                                                                                        |         |     |
|-----|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|-----|
| K41 | Leverandøren skal have strukturerede og regelmæssige uddannelsesprogrammer relateret til sikkerhed for medarbejdere, herunder specifikke uddannelsesprogrammer for nyansatte til induktion af databeskyttelsesforhold. | A.7.2.2 | J.2 |
| K42 | Leverandøren skal sikre, at der udarbejdes en træningsplan med definerede mål relateret til sikkerhed. Træningsplanen skal gennemføres årligt.                                                                         | A.7.2.2 | J.3 |

## 12. ADGANGSKONTROL

| Krav-ID | Krav                                                                                                                                                                                                                                                                                                                             | ISO27001-referenc e | ENISA referen ce |
|---------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K43     | Leverandøren skal fastlægge, dokumentere og vedligeholde en politik for adgangskontrol i relation til Kontraktens opfyldelse i overensstemmelse med den til enhver tid gældende risikovurdering                                                                                                                                  | A.9.1.1             | K.1              |
| K44     | Leverandøren skal minimere brugen af fælleskonti i relation til Kontraktens opfyldelse. Såfremt brugen af fælleskonti er nødvendig, skal Leverandøren sikre, at alle brugere af en given fælleskonto er autoriseret til at benytte de oplysninger, fælleskontoen giver adgang til.                                               | A.9.4.4             | K.2              |
| K45     | Leverandøren skal sikre, at der implementeres en adgangskontrolmekanisme (baseret på adgangskontrol-politikken), der giver adgang til it-systemet. Der skal i den forbindelse som minimum anvendes en kombination med brugernavn/adgangskode. Adgangskoderne skal respektere et bestemt (konfigurerbart) niveau af kompleksitet. | A.9.4.3             | K.3              |
| K46     | Leverandøren skal sikre, at adgangskontrolsystemet registrerer og nægter oprettelse af adgangskoder, der ikke respekterer et bestemt (konfigurerbart) niveau af kompleksitet.                                                                                                                                                    | A.9.4.3             | K.4              |
| K47     | Leverandøren skal definere og dokumentere en adgangskodepolitik. Adgangskodepolitikken skal som minimum indeholde oplysning om adgangskoders længde, kompleksitet, gyldighedsperiode samt antal acceptable mislykkede loginforsøg.                                                                                               | A.9.1.1             | K.5              |
| K48     | Leverandøren skal sørge for, at adgangskoder gemmes i en "hashed"-formular.                                                                                                                                                                                                                                                      | A.9.4.3             | K.6              |

|     |                                                                                                                                                                                                               |         |     |
|-----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|-----|
| K49 | Leverandøren skal i relation til Kontraktens opfyldelse som udgangspunkt benytte to-faktor autentifikation i forbindelse med adgangsstyring til it-systemer med personoplysninger.                            | N/A     | K.7 |
| K50 | Leverandøren skal benytte autentificering af informationsaktiver for at sikre, at behandling af personoplysninger i relation til Kontraktens opfyldelse kun sker via dertil autoriserede informationsaktiver. | A.9.3.1 | K.8 |

### 13. LOGNING OG OVERVÅGNING

| Krav-ID | Krav                                                                                                                                                                                                                                                                         | ISO27001-referenc e | ENISA referen ce |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K51     | Leverandøren skal sikre, at logning udføres, opbevares og gennemgås regelmæssigt. Logning skal omfatte registrering af brugeraktivitet, adgang til data (læse, ændre og slette), undtagelser, fejl og informationssikkerhedshændelser i relation til Kontraktens opfyldelse. | A.12.4.1            | L.1              |
| K52     | Leverandøren skal beskytte logningsfaciliteter og logoplysninger i relation til Kontraktens opfyldelse mod manipulation og uautoriseret adgang.                                                                                                                              | A.12.4.2            | L.2              |
| K53     | Leverandøren skal sikre, at urene i alle relevante informationsbehandlingssystemer, der anvendes til Kontraktens opfyldelse, er synkroniseret til en enkelt referencetidskilde.                                                                                              | A.12.4.4            | L.2              |
| K54     | Leverandøren skal sikre, at aktiviteter udført af systemadministratorer og systemoperatører i relation til Kontraktens opfyldelse logges, og Leverandøren skal beskytte disse logge og gennemgå disse regelmæssigt.                                                          | A.12.4.3            | L.3              |
| K55     | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at der ikke er mulighed for sletning eller modifikation af logningsfiler. Adgangen til logningsfiler skal også logges i tilknytning til monitorering af usædvanlig aktivitet.                                 | N/A                 | L.4              |
| K56     | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at et overvågningssystem behandler logningsfilerne og producerer rapporter om systemets status samt giver besked om eventuelle advarsler.                                                                     | N/A                 | L.5              |

## 14. DRIFTSSIKKERHED

| Krav-ID | Krav                                                                                                                                                                                                                                    | ISO27001-referenc e | ENISA referen ce |
|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K57     | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at databaseservere og applikationsservere konfigureres, således at de kører ved hjælp af en separat konto med minimale operativsystemprivilegier for at fungere korrekt. | A.12.5.1            | M.1              |
| K58     | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at databaseservere og applikationsservere kun behandler personoplysninger, der er nødvendige for at opnå formålet med behandlingen.                                      | A.12.5.1            | M.2              |
| K59     | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at krypteringsløsninger for specifikke filer eller optagelser er implementeret.                                                                                          | N/A                 | M.3              |
| K60     | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at kryptering af harddiske er implementeret, hvor det er nødvendigt.                                                                                                     | A.18.1.5            | M.4              |
| K61     | Leverandøren skal i relation til Kontraktens opfyldelse anvende pseudonymiseringsteknikker for at undgå at forbinde data til registrerede uden yderligere oplysninger.                                                                  | N/A                 | M.5              |
| K62     | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at der anvendes teknikker på databaseniveau, såsom autoriserede forespørgsler, søgbare krypteringer osv., der understøtter privatlivets fred.                            | N/A                 | M.6              |

## 15. SIKKERHEDSKRAV TIL INFORMATIONSSYSTEMER

| Krav-ID | Krav                                                                                                                              | ISO27001-referenc e | ENISA referen ce |
|---------|-----------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K63     | Leverandøren skal sikre, at brugere ikke har adgang til at deaktivere sikkerhedsinstallationer.                                   | A.12.2.1            | N.1              |
| K64     | Leverandøren skal sikre, at anti-virus applikationer konfigureres ugentlig.                                                       | A.12.2.1            | N.2              |
| K65     | Leverandøren skal sikre, at brugere ikke er autoriserede til at installere eller deaktivere uautoriserede software applikationer. | A.12.6.2            | N.3              |

|     |                                                                                                                                                                                                                                                                             |          |     |
|-----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|-----|
| K66 | Leverandøren skal sikre, at systemet har sessions time-outs, når brugeren har været inaktiv i en nærmere fastlagt periode.                                                                                                                                                  | N/A      | N.4 |
| K67 | Leverandøren skal sikre, at kritiske sikkerhedsopdateringer udgivet af operativsystemudvikleren installeres regelmæssigt.                                                                                                                                                   | A.12.5.1 | N.5 |
| K68 | Leverandøren skal sikre, at anti-virus applikationer konfigureres dagligt.                                                                                                                                                                                                  | A.12.2.1 | N.6 |
| K69 | Leverandøren skal sikre, at der ikke overføres personoplysninger fra arbejdsstationer til eksterne lagerenheder, fx USB, DVD og eksterne harddiske.                                                                                                                         | A.11.2.6 | N.7 |
| K70 | Leverandøren skal sikre, at arbejdsstationer, der anvendes til behandling af personoplysninger, ikke forbindes til internettet, medmindre der er truffet sikkerhedsforanstaltninger for at forhindre uautoriseret behandling, kopiering og overførsel af personoplysninger. | A.14.1.2 | N.8 |
| K71 | Leverandøren skal sikre, at fulddisk-kryptering er aktiveret på arbejdsstationerne.                                                                                                                                                                                         | A.18.1.5 | N.9 |

## 16. KOMMUNIKATIONSSIKKERHED

| Krav-ID | Krav                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | ISO27001-referenc e | ENISA referen ce |
|---------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K72     | Leverandøren skal sikre, at såfremt adgang til it-systemet gives via internettet, skal kommunikationen krypteres via kryptografiske protokoller (såsom TLS / SSL eller tilsvarende).                                                                                                                                                                                                                                                                                                   | A.13.1.1            | O.1              |
| K73     | Leverandøren skal sikre, at trådløs adgang til it-systemet, kun tillades for brugere med et arbejdsbetinget behov for en sådan adgang, samt at trådløs adgang beskyttes af krypteringsmekanismer.                                                                                                                                                                                                                                                                                      | A.13.1.1            | O.2              |
| K74     | Leverandøren skal sikre, at fjernadgang til it-systemet generelt undgås. I tilfælde hvor fjernadgang er absolut nødvendigt, bør det kun udføres under kontrol og overvågning af en bestemt person fra organisationen (for eksempel it-administrator/sikkerhedsansvarlig) ved hjælp af foruddefinerede enheder. Leverandøren skal herunder implementere en politik og understøttende sikkerhedsforanstaltninger til styring af de risici, der opstår ved anvendelse af mobilt udstyr og | A.6.2.1             | O.3              |

|     |                                                                                                                                                                                  |          |     |
|-----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|-----|
|     | fjernarbejdspladser i forbindelse med opfyldelse af Kontrakten.                                                                                                                  |          |     |
| K75 | Leverandøren skal sikre, at aktivitet (trafik) til og fra it-systemet monitoreres og kontrolleres ved brug af firewalls og IDS (Intrusion Detection Systems).                    | N/A      | 0.4 |
| K76 | Leverandøren skal sikre, at servere og arbejdsstationer, der anvendes til behandling af personoplysninger, ikke forbindes til internettet.                                       | N/A      | 0.5 |
| K77 | Leverandøren skal opdele grupper af informationstjenester, brugere og informationssystemer, der anvendes til Kontraktens opfyldelse, i segmenterede netværk.                     | A.13.1.3 | 0.6 |
| K78 | Leverandøren skal sikre, at det ved hjælp af teknikker såsom MAC-filtrering eller Network Access Control (NAC) kun er forhåndsgodkendte enheder, der får adgang til it-systemet. | N/A      | 0.7 |

## 17. BACKUP

| Krav-ID | Krav                                                                                                                                                                                                                                                                                 | ISO27001-referenc e | ENISA referen ce |
|---------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K79     | Leverandøren skal sikre, at der i overensstemmelse med dokumenterede procedurer udføres backup af information, programmel og system-images, der anvendes til Kontraktens opfyldelse. Backup-procedurer skal være relateret til Leverandørens dokumenterede roller og ansvarsområder. | A12.3.1             | P.1              |
| K80     | Leverandøren skal sikre, at backup gives et passende niveau af fysisk beskyttelse, der er i overensstemmelse med de det niveau, der anvendes på de originale data.                                                                                                                   | N/A                 | P.2              |
| K81     | Leverandøren skal sikre, at udførelsen af backup overvåges for at sikre fuldstændighed.                                                                                                                                                                                              | N/A                 | P.3              |
| K82     | Leverandøren skal sikre, at der regelmæssigt udføres backup.                                                                                                                                                                                                                         | A12.3.1             | P.4              |
| K83     | Leverandøren skal sikre, at backup-medier testes regelmæssigt for derved at sikre, at backup-data kan anvendes, hvis det bliver nødvendigt.                                                                                                                                          | N/A                 | P.5              |
| K84     | Leverandøren skal sikre, at inkrementelle backups udføres mindst en gang dagligt.                                                                                                                                                                                                    | N/A                 | P.6              |

|     |                                                                                                            |     |     |
|-----|------------------------------------------------------------------------------------------------------------|-----|-----|
| K85 | Leverandøren skal sikre, at kopier af backups opbevares på forskellige lokationer.                         | N/A | P.7 |
| K86 | Leverandøren skal sikre, at backup krypteres i tilfælde hvor der anvendes tredjepartstjenester til backup. | N/A | P.8 |

## 18. MOBILT UDSTYR OG FJERNARBEJDSPLADSER

| Krav-ID | Krav                                                                                                                                                                                                                                                                                         | ISO27001-referencer | ENISA reference |
|---------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|-----------------|
| K87     | Leverandøren skal implementere en politik og understøttende sikkerhedsforanstaltninger til styring af de risici, der opstår ved anvendelse af mobilt udstyr i forbindelse med opfyldelse af Kontrakten.                                                                                      | A.6.2.1             | Q.1             |
| K88     | Leverandøren skal sikre, at mobilt udstyr, der giver adgang til it-systemet i relation til Kontraktens opfyldelse, er forhåndsregistret og forhåndsgodkendt.                                                                                                                                 | A.6.2.1             | Q.2             |
| K89     | Leverandøren skal sikre, at mobilt udstyr, der anvendes i relation til Kontraktens opfyldelse er underlagt samme niveau af adgangskontrolprocedurer (til systemer, hvori der behandles personoplysninger) som andre arbejdsstationer mv, der anvendes i relation til Kontraktens opfyldelse. | A.6.2.1             | Q.3             |
| K90     | Leverandøren skal definere specifikke roller og ansvarsområder med hensyn til administration af mobilt udstyr og fjernarbejdspladser i relation til Kontraktens opfyldelse.                                                                                                                  | A.6.2.1             | Q.4             |
| K91     | Leverandøren skal sikre, at der kan slettes personoplysninger på mobilt udstyr, der anvendes i relation til Kontraktens opfyldelse, såfremt det pågældende mobile udstyr kompromitteres.                                                                                                     | A.6.2.1             | Q.5             |
| K92     | Leverandøren skal sikre, at det mobile udstyr, der anvendes i relation til Kontraktens opfyldelse, understøtter adskillelse af privat- og arbejdsrelateret brug af det mobile udstyr.                                                                                                        | A.6.2.1             | Q.6             |
| K93     | Leverandøren skal sikre, at mobilt udstyr, der anvendes i relation til Kontraktens opfyldelse, er fysisk beskyttet mod tyveri, når det ikke er i brug.                                                                                                                                       | A.6.2.1             | Q.7             |
| K94     | Leverandøren skal sikre, at der benyttes to-faktor-autentifikation, såfremt personoplysninger, der er omfattet af Kontrakten, tilgås via mobilt udstyr.                                                                                                                                      | A.6.2.1             | Q.8             |

|     |                                                                                                                          |         |     |
|-----|--------------------------------------------------------------------------------------------------------------------------|---------|-----|
| K95 | Leverandøren skal sikre, at personoplysninger, der er omfattet af Kontrakten, og som gemmes på mobilt udstyr, krypteres. | A.6.2.1 | Q.9 |
|-----|--------------------------------------------------------------------------------------------------------------------------|---------|-----|

## 19. SÅRBARHEDSSTYRING OG SIKKERHED I UDVIKLINGS- OG HJÆLPEPROCESSER

| Krav-ID | Krav                                                                                                                                                                                                                          | ISO27001-referenc e | ENISA referen ce |
|---------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|------------------|
| K96     | Leverandøren skal fastlægge og anvende regler i overensstemmelse med best practice for udvikling af programmel, som Leverandøren anvender til Kontraktens opfyldelse.                                                         | A.14.2.1            | R.1              |
| K97     | Leverandøren skal sikre, at sikkerhedsrelaterede krav indgår i kravene til nye informationssystemer eller forbedringer af eksisterende informationssystemer, som Leverandøren anvender i relation til Kontraktens opfyldelse. | A.14.1.1            | R.2              |
| K98     | Leverandøren skal implementere privatlivsfremmende teknologier (Privacy Enhancing Technologies (PET)) til beskyttelse af personoplysninger i forbindelse med Kontraktens opfyldelse.                                          | N/A                 | R.3              |
| K99     | Leverandøren skal sikre, at standarder for sikker kodning følges i forbindelse med Kontraktens opfyldelse.                                                                                                                    | A.14.2.1            | R.4              |
| K100    | Leverandøren skal etablere godkendelsestestprogrammer og relaterede kriterier for nye informationssystemer, opgraderinger og nye versioner af programmel, som Leverandøren anvender i relation til Kontraktens opfyldelse.    | A.14.2.9            | R.5              |
| K101    | Leverandøren skal i relation til Kontraktens opfyldelse evaluere it-systemers eksponering for sårbarheder inden idriftsættelse og iværksætte passende foranstaltninger for at håndtere den tilhørende risiko.                 | A.12.6.1            | R.6              |
| K102    | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at der udføres regelmæssig penetrationstestning af it-systemer.                                                                                                | A.12.6.1            | R.7              |
| K103    | Leverandøren skal i relation til Kontraktens opfyldelse have en dokumenteret proces for løbende indhentning af informationer om sårbarheder i it-systemer.                                                                    | A.12.6.1            | R.8              |
| K104    | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at software patches testes og evalueres, før de installeres i produktionsmiljøet.                                                                              | A.12.6.1            | R.9              |

## 20. MEDIEHÅNDTERING OG UDSTYR

| Krav-ID | Krav                                                                                                                                                                                                                                                       | ISO2700 1-referenc e | ENISA referen ce |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|------------------|
| K105    | Leverandøren skal bortskaffe medier, der har været anvendt til Kontraktens opfyldelse, når der ikke længere er brug for dem, på forsvarlig vis og i overensstemmelse med formelle procedurer.                                                              | A.8.3.2              | S.1              |
| K106    | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at der sker makulering af dokumenter med personoplysninger, når dokumenterne ikke længere skal gemmes.                                                                                      | A.8.3.2              | S.2              |
| K107    | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at der udføres flere softwarebaserede overskrivninger, før det pågældende medie ikke længere skal anvendes.                                                                                 | N/A                  | S.3              |
| K108    | Leverandøren skal sikre, at såfremt organisationen i relation til Kontraktens opfyldelse benytter tredjeparter (dvs. underdatabehandlere) til destruktion af medier og fysiske filer (papir), skal der være indgået en skriftlig aftaler herom.            | A.8.3.3 og A. 11.2.7 | S.4              |
| K109    | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at der efter softwaresletning udføres yderligere fysiske sikkerhedsforanstaltninger såsom afmagnetisering, fysisk destruktion eller lignende.                                               | A.8.3.3 og A. 11.2.7 | S.5              |
| K110    | Leverandøren skal sikre, at såfremt organisationen i relation til Kontraktens opfyldelse benytter tredjeparter (dvs. underdatabehandlere) til destruktion af medier og fysiske filer (papir), finder processen fortrinsvis sted på Leverandørens lokation. | N/A                  | S.6              |

## 21. SIKRE OMRÅDER

| Krav-ID | Krav                                                                                                                                                                   | ISO2700 1-referenc e | ENISA referen ce |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|------------------|
| K111    | Leverandøren skal beskytte fysiske områder i relation til Kontraktens opfyldelse med passende adgangskontrol for at sikre, at kun autoriseret personale kan få adgang. | A.11.1.2             | T.1              |
| K112    | Leverandøren skal sikre, at fysiske områder, der anvendes til Kontraktens opfyldelse, og hvor                                                                          | A.11.1.6             | T.2              |

|      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |          |     |
|------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|-----|
|      | uautoriserede personer kan komme ind på Leverandørens område, kontrolleres, f.eks. via adgangskort og gæstekort, for at undgå uautoriseret adgang.                                                                                                                                                                                                                                                                                                                         |          |     |
| K113 | Leverandøren skal i det relevante omfang definere sikre områder, der anvendes til Kontraktens opfyldelse, og beskytte disse med passende foranstaltninger, herunder føre en fysisk logbog eller elektronisk revisionsspør af al adgang til sikre områder.                                                                                                                                                                                                                  | A.11.1.3 | T.3 |
| K114 | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at der installeres detekteringssystemer i alle sikre områder.                                                                                                                                                                                                                                                                                                                                               | A.11.1.1 | T.4 |
| K115 | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at der etableres fysisk sikring, hvor det er relevant, for at forhindre uautoriseret fysisk adgang.                                                                                                                                                                                                                                                                                                         | A.11.1.1 | T.5 |
| K116 | Leverandøren skal i relation til Kontraktens opfyldelse sikre, at ledige sikre områder er fysisk aflåst og regelmæssigt efterses.                                                                                                                                                                                                                                                                                                                                          | A.11.1.1 | T.6 |
| K117 | Leverandøren skal tilrettelægge og etablere fysisk beskyttelse af informationsbehandlingsfaciliteter, der anvendes til Kontraktens opfyldelse, mod naturkatastrofer, ondsindede angreb eller ulykker, herunder brand, oversvømmelse, jordskælv, eksplosion, borgerlige uroligheder og andre former for natur- eller menneskeskabte katastrofer. Leverandøren kan bl.a. benytte automatisk brandbekæmpelsessystem, et dedikeret klimaanlæg og separat strømforsyning (UPS). | A.11.1.4 | T.7 |
| K118 | Leverandøren skal sikre, at eksternt servicepersonale kun får begrænset adgang til sikre områder.                                                                                                                                                                                                                                                                                                                                                                          | A.11.1.6 | T.8 |